

Respuesta ante Ransomware

- NIST SP 800-61
- MITRE ATT&CK
- SANS
- ISO/IEC 27035

PREPARACIÓN · CONTINUO

Backups 3-2-1 con copia inmutable / air-gapped, probados periódicamente · hardening base (MFA, segmentación, bloqueo vssadmin.exe) · runbooks SOAR preconfigurados.

FASE 1 **Detección y Análisis**

FASE 2 **Contención**

FASE 3 **Erradicación**

FASE 4 **Recuperación**

FASE 5 **Lecciones Aprendidas**

NOTACIÓN DEL DIAGRAMA

INICIO / FIN

Círculo celeste
Inicio y fin del flujo

ACCIÓN / PROCESO

Rectángulo amarillo
Paso operativo

DECISIÓN

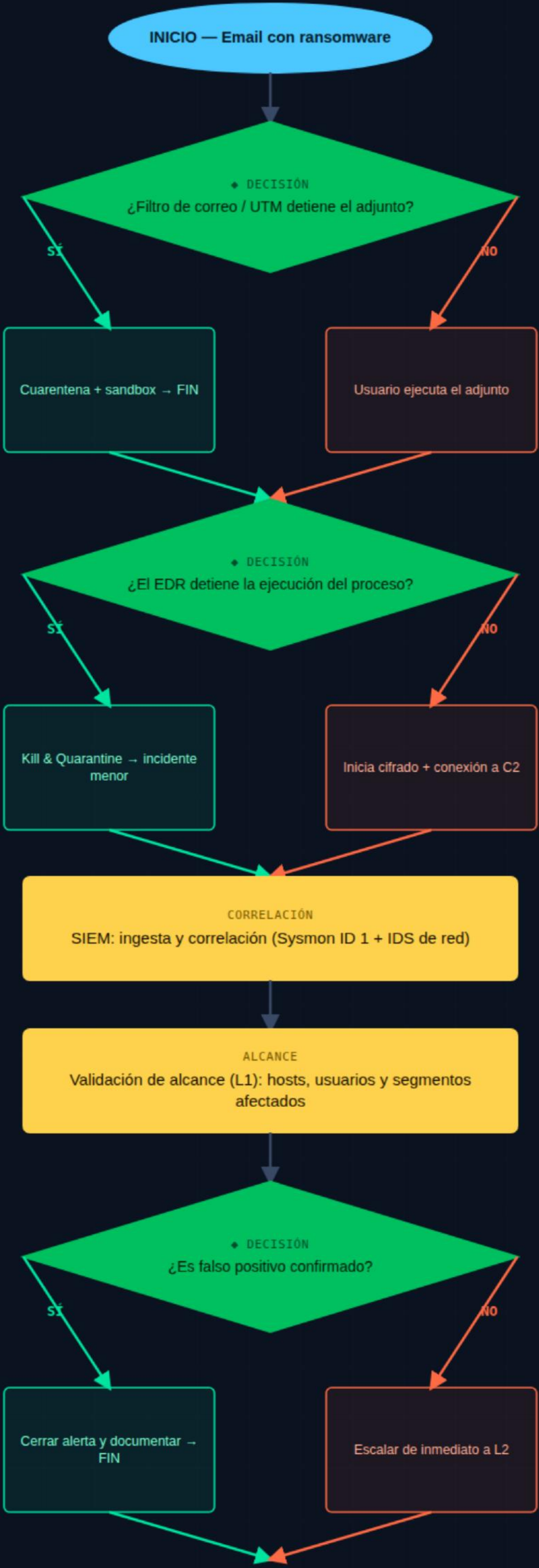
Rombo verde
Punto de decisión Sí / No

VÍA MANUAL

Recuadro punteado naranja
Contingencia manual

Respuesta ante Ransomware

● FASE 1 – Detección y Análisis

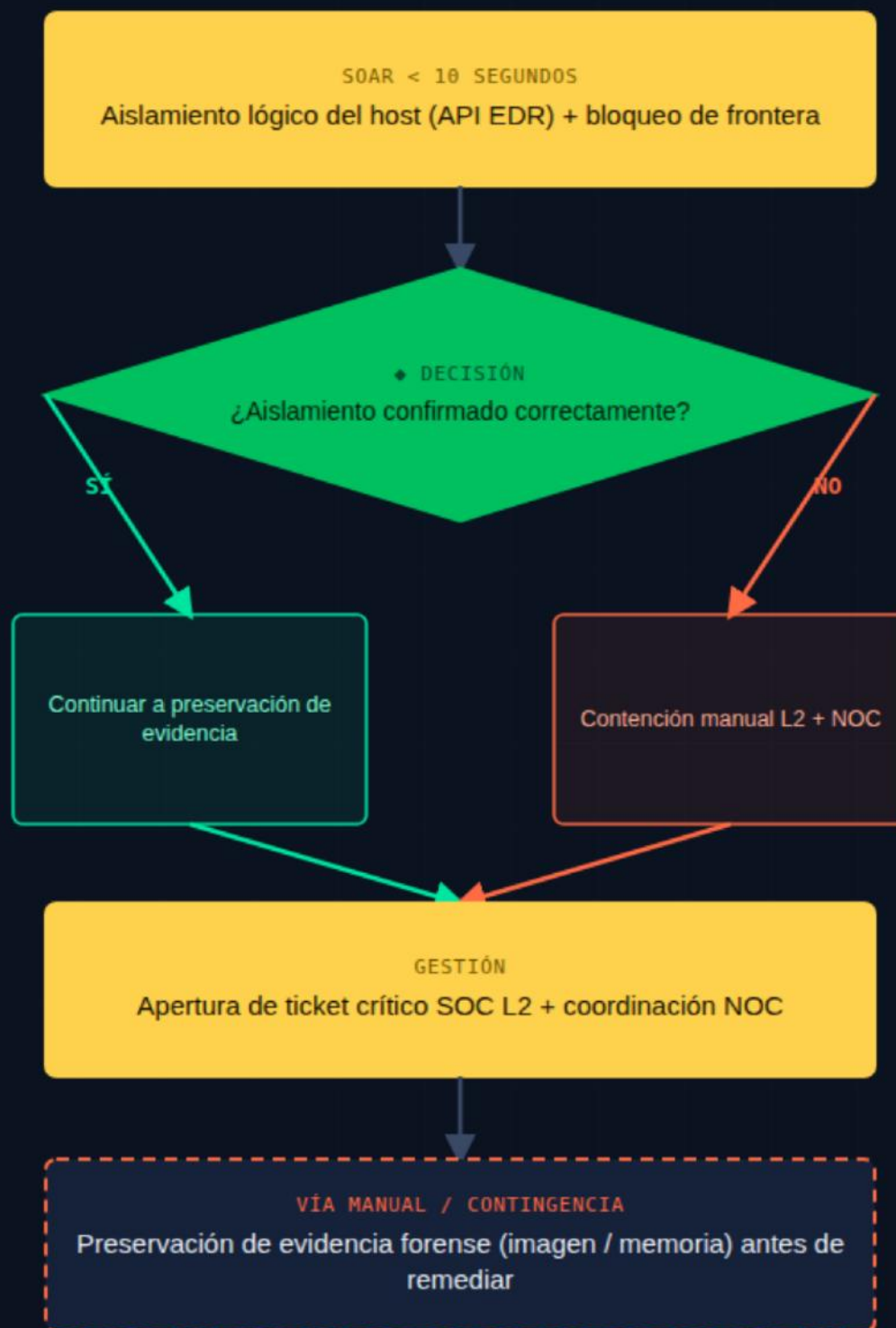


HERRAMIENTAS — DETECCIÓN Y ANÁLISIS

- CrowdStrike Falcon
- SentinelOne
- Splunk Enterprise Security
- Suricata IDS
- Wazuh + Sysmon

Respuesta ante Ransomware

• FASE 2 – Contención

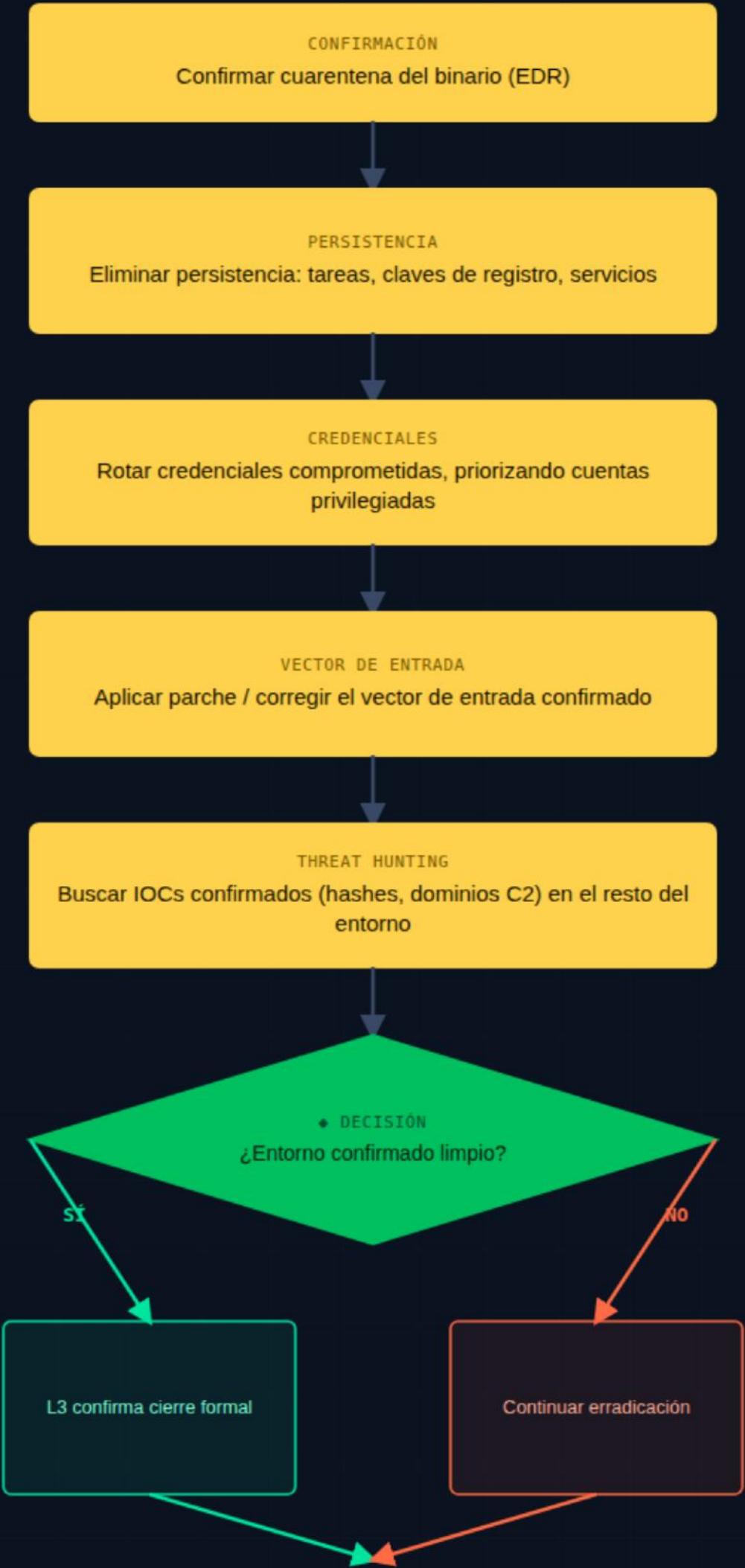


HERRAMIENTAS – CONTENCIÓN

- ▶ Fortinet FortiGate
- ▶ Palo Alto NGFW
- ▶ Cortex XSOAR
- ▶ Shuffle (SOAR open-source)
- ▶ pfSense / OPNsense

Respuesta ante Ransomware

● FASE 3 – Erradicación

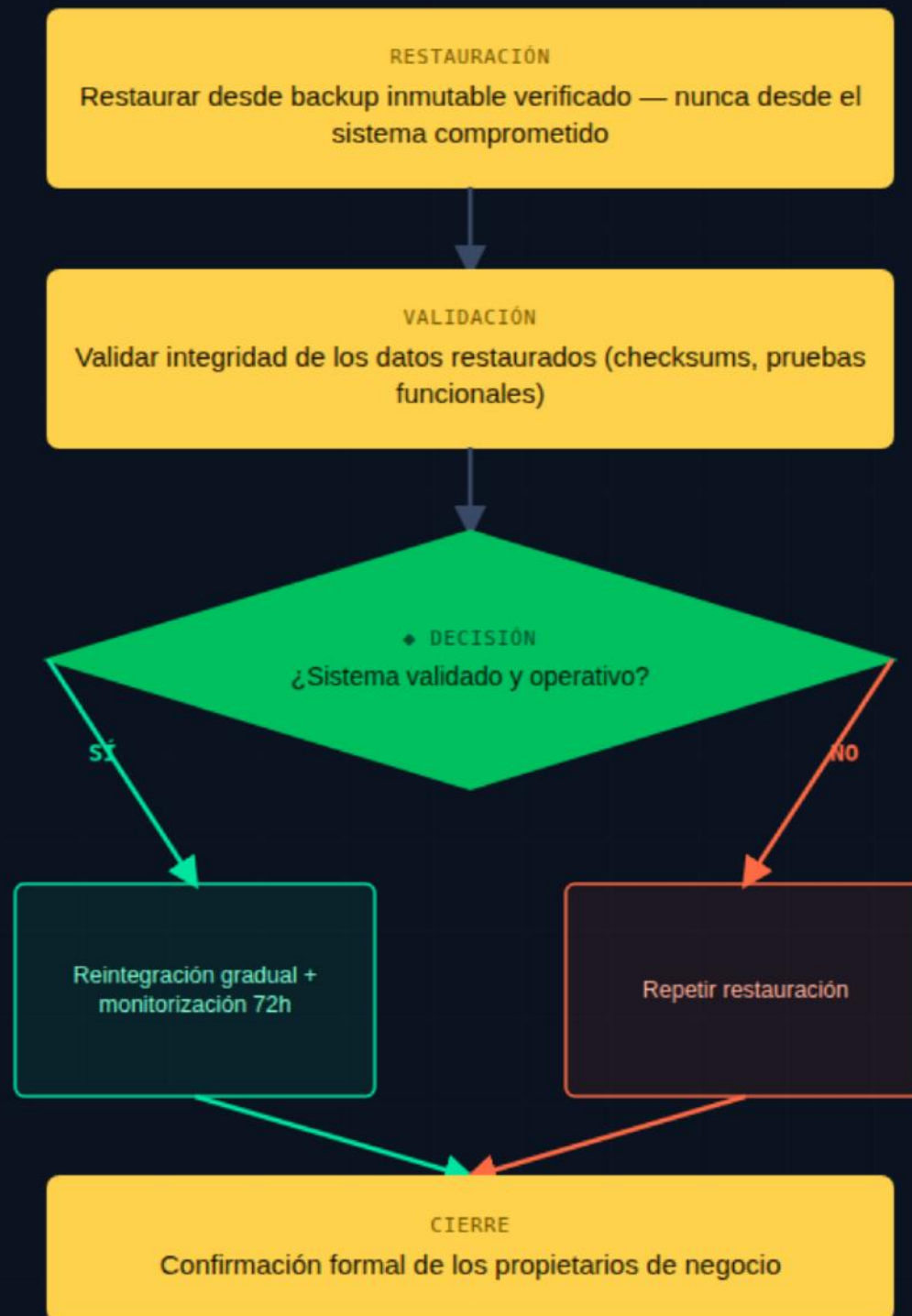


HERRAMIENTAS – ERRADICACIÓN

- CrowdStrike Falcon
- Velociraptor (forense / DFIR)
- SentinelOne
- Microsoft Defender for Endpoint

Respuesta ante Ransomware

• FASE 4 – Recuperación

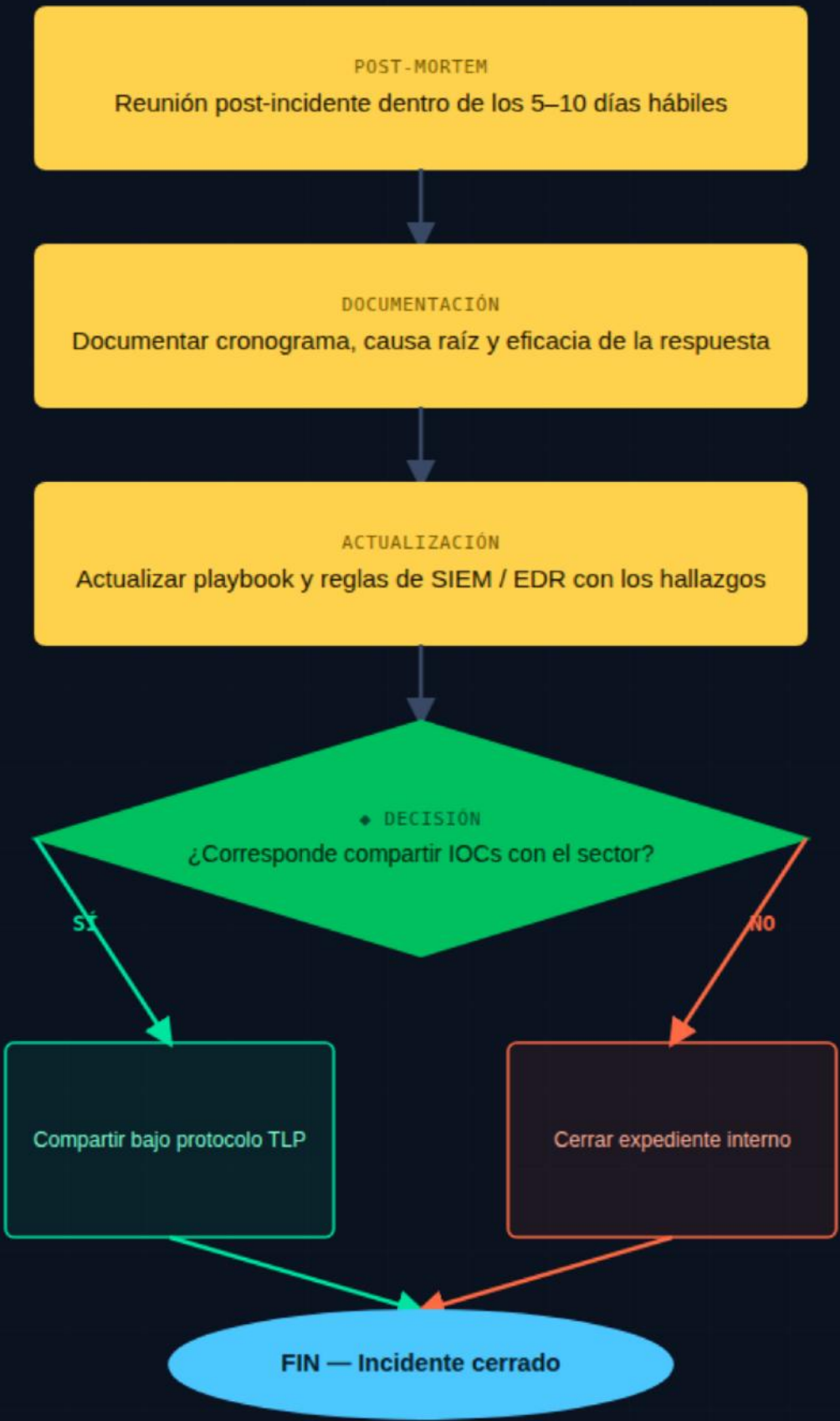


HERRAMIENTAS – RECUPERACIÓN

- Veeam Backup & Replication
- Cohesity DataProtect
- Rubrik Security Cloud
- Datadog

Respuesta ante Ransomware

● FASE 5 – Lecciones Aprendidas



HERRAMIENTAS – LECCIONES APRENDIDAS

- ▶ TheHive
- ▶ ServiceNow ITSM
- ▶ Jira Service Management
- ▶ Confluence

CONFIDENCIAL — USO INTERNO

PLAYBOOK DE RESPUESTA ANTE INCIDENTES

Procedimiento Operativo Estándar frente a Ataques de Ransomware

SOC-IR-042 · Versión 2.0

Código	SOC-IR-042
Versión	2.0
Clasificación	Confidencial / Uso Interno
Estado	Vigente
Marcos de referencia	NIST SP 800-61 Rev. 2 · MITRE ATT&CK · SANS · ISO/IEC 27035
Última revisión	20 de junio de 2026
Autor	Equipo de Ingeniería del SOC
Aprobado por	CISO

1. Resumen Ejecutivo

Este playbook establece el procedimiento operativo estándar para detectar, contener, erradicar y recuperar la infraestructura corporativa frente a un ataque de ransomware, así como para coordinar la comunicación interna, regulatoria y externa asociada. Cubre el ciclo completo de gestión de incidentes conforme a NIST SP 800-61 Rev. 2 (Preparación, Detección y Análisis, Contención, Erradicación, Recuperación y Actividad Post-Incidente), integrando un flujo de detección y contención automatizada (SIEM/EDR/SOAR) con los procedimientos manuales, los roles de decisión y las obligaciones de comunicación necesarios para cerrar un incidente de forma completa y auditable.

El objetivo es interrumpir la propagación del ataque —movimiento lateral y cifrado— en el menor tiempo posible, preservando simultáneamente la evidencia necesaria para la investigación, la continuidad operativa y el cumplimiento regulatorio. La versión 2.0 incorpora las nueve brechas identificadas en la revisión del documento v1.0 original.

! Este playbook NO debe operacionalizarse en su forma v1.0 original. La v2.0 es la única versión autorizada para uso operativo. Ver Informe de Revisión SOC-IR-042 para el detalle de las brechas corregidas.

2. Alcance y Marco de Referencia

Nombre: Respuesta ante Incidentes de Ransomware

Código: SOC-IR-042 · Versión 2.0

Cubre: cifrado malicioso de archivos en endpoints y servidores corporativos, con vectores de entrada por phishing/adjunto malicioso, explotación de servicios expuestos (RDP/VPN) o compromiso previo de credenciales.

No cubre: incidentes de exfiltración de datos sin cifrado (ver playbook específico de exfiltración), ataques de denegación de servicio (ver SOC-IR-043), ni accesos no autorizados sin payload de cifrado confirmado.

Marcos de referencia:

- NIST SP 800-61 Rev. 2 — ciclo de vida de gestión de incidentes.
- MITRE ATT&CK — TTPs cubiertos en la sección 7.
- SANS Incident Handler's Handbook — estructura PICERL y buenas prácticas operativas.
- ISO/IEC 27035 — gestión de incidentes, roles, comunicación y mejora continua.

3. Trigger / Criterios de Activación

Este playbook se activa formalmente ante cualquiera de los siguientes eventos:

- Alerta del EDR clasificada como ransomware o como cifrado masivo de archivos en un host.
- Correlación SIEM: proceso hijo de una aplicación de usuario (correo, lector PDF, navegador) que invoca un intérprete de comandos con argumentos codificados, seguido de conexión saliente a IP externa sin resolución DNS previa.

- Detección de modificación o renombrado masivo de extensiones de archivo en un endpoint o recurso compartido en un intervalo corto de tiempo.
- Presencia de notas de rescate (ransom notes) en sistemas de archivos o reporte directo de un usuario sobre archivos inaccesibles o pantalla de rescate.
- Coincidencia de hash o IOC contra un feed de threat intelligence asociado a una familia de ransomware conocida.
- Alerta de bloqueo de vssadmin.exe o intentos de eliminación de Shadow Copies (T1490).

4. Roles y Responsables

Rol	Responsabilidad en el playbook	Fase principal
Analista SOC L1	Triage inicial de la alerta, descarte de falso positivo, escalado a L2	Detección y Análisis
Analista SOC L2	Investigación y validación de IOCs; ejecuta contención manual si el SOAR falla	Detección / Contención
Analista SOC L3 / Threat Hunter	Análisis forense, búsqueda de persistencia y artefactos residuales; confirma cierre de erradicación	Erradicación
IR Lead	Activa formalmente el playbook, coordina fases, autoriza acciones de alto impacto; único autorizado para aprobar postura ante rescate junto a Dirección	Todas
Equipo de Infraestructura / Backup	Valida integridad de copias de seguridad y ejecuta la restauración desde backup inmutable	Recuperación
NOC (Network Operations Center)	Coordina con el SOC los aislamientos de red; evita reconexiones no autorizadas del host aislado	Contención
Legal / DPO	Evalúa obligaciones de notificación regulatoria (RGPD, NIS2, normativa sectorial). Plazo máximo: 72 horas desde el conocimiento del incidente bajo RGPD	Comunicación
Comunicación / RRPP	Gestiona comunicación externa bajo aprobación de Dirección; ningún miembro técnico hace declaraciones externas	Comunicación
CISO / Dirección	Aprueba decisiones críticas: escalado mayor, postura ante el rescate, paro de operaciones. NUNCA se paga rescate sin autorización expresa y documentada	Escalado mayor

5. Diagrama de Flujo General

El procedimiento integra la lógica de decisión técnica (filtro de correo, EDR, SOAR) dentro del ciclo completo de respuesta: Detección y Análisis, Contención, Erradicación, Recuperación y Lecciones Aprendidas. Notación: círculo = inicio/fin · rectángulo = acción · rombo = decisión · recuadro rojo = vía de contención manual (activa solo si el SOAR falla).

- Documento independiente: Diagrama_Flujo_Ransomware_SOC-IR-042 — formato PDF (póster vectorial), Word y SVG editable. Incluye ≥3 opciones de herramientas por fase.

6. Fases del Proceso (Ciclo NIST SP 800-61)

6.0 Preparación

- Verificar que la política de copias de seguridad cumple el esquema 3-2-1 e incluye al menos una copia inmutable o air-gapped, no accesible desde la red de producción.
- Probar periódicamente la restauración desde backup (no solo su existencia) para confirmar tiempos reales de recuperación (RTO/RPO).
- Mantener hardening base: deshabilitar macros por defecto, MFA en accesos remotos, segmentación de red entre entornos críticos y de usuario, principio de mínimo privilegio, bloqueo de vssadmin.exe por política de EDR.
- Mantener actualizado el inventario de activos críticos y el directorio de contactos de escalado.
- Validar el playbook mediante tabletop exercises al menos semestralmente, incluyendo las fases de Erradicación y Recuperación.

6.1 Detección y Análisis

- **Telemetría de host:** monitorizar creación de subprocesos con Sysmon Event ID 1. Se detecta proceso de usuario (cliente de correo o lector PDF) que invoca powershell.exe o cmd.exe con argumentos codificados en Base64.
- **Telemetría de red:** el IDS identifica conexiones salientes a IPs externas sin resolución DNS previa o vinculadas a servidores C2 conocidos.
- **Validación de alcance:** el Analista L1 confirma cuántos hosts presentan el mismo patrón, qué usuarios están involucrados y qué segmentos de red podrían verse afectados mediante búsqueda retrospectiva en el SIEM.
- **Descarte de falso positivo:** si se confirma actividad maliciosa (no falso positivo), escalar de inmediato a L2. Si es falso positivo, cerrar alerta, documentar y ajustar la regla de detección.

6.2 Contención

- ▀ La contención automatizada es el corazón de este playbook. El SOAR debe aislar el host en menos de 10 segundos. El aislamiento manual es la vía de respaldo, nunca la principal.

- **Aislamiento lógico vía SOAR (< 10 segundos):** instrucción API al agente del EDR para cortar todo el tráfico de red del host, manteniendo activo exclusivamente el canal TLS de gestión con la consola del SOC.
- **Bloqueo de frontera vía SOAR:** actualización dinámica de blocklists del firewall perimetral para cortar la comunicación hacia el C2 externo.
- **Punto de control:** ¿aislamiento confirmado correctamente?

- **Si NO (timeout o error de API del SOAR):** el Analista L2 ejecuta contención manual: deshabilitar la cuenta comprometida en directorio activo, bloquear acceso VPN/RDP del segmento afectado, solicitar al NOC aislamiento físico coordinado del puerto de red.
- **Coordinación NOC:** el SOAR abre ticket crítico indicando que el aislamiento es controlado, para evitar que el NOC reconecte físicamente la interfaz por error.
- **Preservación de evidencia forense:** ANTES de cualquier acción de remediación adicional, el Analista L2/L3 captura imagen forense o volcado de memoria del host cuando sea viable, conforme a la cadena de custodia interna. Esta evidencia es necesaria para investigación, seguro cibernético y procedimiento legal.

6.3 Erradicación

- Confirmar mediante el EDR que el binario causante fue puesto en cuarentena y que no existen procesos activos asociados en otros hosts del mismo segmento.
- Identificar y eliminar mecanismos de persistencia: tareas programadas, claves de ejecución automática, servicios creados. Documentar cada artefacto.
- Rotar credenciales de todas las cuentas que hayan iniciado sesión en el host comprometido durante la ventana del incidente, priorizando cuentas con privilegios elevados.
- Aplicar el parche o corrección del vector de entrada confirmado antes de reintegrar cualquier sistema a producción.
- Ejecutar threat hunting con los IOCs confirmados (hashes, dominios C2, claves de registro) contra el resto del entorno para descartar afectación adicional no detectada por las alertas iniciales.
- El Analista L3 confirma formalmente el cierre de esta fase antes de autorizar el paso a Recuperación.

6.4 Recuperación

- Restaurar los sistemas desde la copia de seguridad inmutable/air-gapped más reciente verificada como íntegra. Nunca restaurar desde el sistema comprometido.
- Validar la integridad de los datos restaurados (checksums, pruebas funcionales) antes de reconectar el sistema a la red de producción.
- Reintegrar los sistemas de forma gradual, con monitorización reforzada (alertas de baja tolerancia) durante al menos 72 horas tras la reconexión.
- Rotar certificados y credenciales de servicio potencialmente expuestos, además de las cuentas de usuario ya rotadas en Erradicación.
- Obtener confirmación formal de los propietarios de negocio sobre la operatividad restaurada antes de cerrar el incidente.

6.5 Lecciones Aprendidas

- Convocar reunión post-incidente dentro de los 5-10 días hábiles posteriores al cierre, con todos los roles de la sección 4.
- Documentar el cronograma completo del incidente, la causa raíz confirmada y la eficacia de cada fase de la respuesta.
- Actualizar este playbook, las reglas de detección del SIEM y las políticas del EDR con los hallazgos obtenidos.
- Compartir los IOCs con la comunidad del sector o el CSIRT nacional bajo el protocolo TLP adecuado si corresponde.

7. Mapeo a MITRE ATT&CK

Fase	Táctica (ID)	Técnica (ID)	Evidencia / detección
Detección	Initial Access (TA0001)	T1566 Phishing	Vector de entrada por correo electrónico malicioso
Detección	Execution (TA0002)	T1059.001 PowerShell	Comandos codificados detectados vía Sysmon Event ID 1
Detección	Command and Control (TA0011)	T1071 Application Layer Protocol	Conexión a IP externa sin resolución DNS previa
Contención	Lateral Movement (TA0008)	T1021 Remote Services	Objetivo del aislamiento de red automatizado
Contención	Impact (TA0040)	T1486 Data for Encrypted Impact	Cifrado de archivos detectado en el host
Contención	Impact (TA0040)	T1490 Inhibit System Recovery	Bloqueo de vssadmin.exe (eliminación de Shadow Copies)
Erradicación	Persistence (TA0003)	T1547 Boot or Logon Autostart Execution	Búsqueda de persistencia en tareas programadas y claves de registro
Erradicación	Defense Evasion (TA0005)	T1070 Indicator Removal	Eliminación de logs por el atacante para dificultar el análisis forense

8. Herramientas y Configuraciones Críticas

Componente	Herramientas de referencia	Configuraciones críticas
Perímetro y red	Fortinet FortiGate, Palo Alto NGFW, pfSense / OPNsense	Sandbox inline activo; inspección SSL/TLS saliente; listas negras dinámicas por reputación IP.
Seguridad Endpoint (EDR)	CrowdStrike Falcon, SentinelOne, Wazuh Agent + Sysmon	Modo Enforce/Protection activo. Kill & Quarantine automático. Bloqueo estricto de vssadmin.exe.
SIEM	Splunk Enterprise Security, Microsoft Sentinel, Wazuh	Ingesta de logs de Sysmon. Reglas de correlación MITRE ATT&CK. Alertas sobre proceso hijo con argumentos codificados.
SOAR	Cortex XSOAR, Shuffle (open-source), Tines	Webhooks con credenciales seguras vía API al EDR y firewall. Bloques de contingencia si falla la primera API. Aislamiento en < 10 segundos.

Componente	Herramientas de referencia	Configuraciones críticas
Backup / Recuperación	Veeam Backup & Replication, Cohesity DataProtect, Rubrik Security Cloud	Política 3-2-1. Inmutabilidad WORM. Air-gapped o cloud-isolated. Pruebas de restauración periódicas documentadas.
Forense	Velociraptor (DFIR), FTK Imager, Volatility	Imagen forense de disco y volcado de memoria antes de cualquier remediación. Cadena de custodia documentada.
Gestión de incidentes	TheHive, ServiceNow ITSM, Jira Service Management	Plantillas de escalado automático para L2. Centralización de hashes e IOCs. Campo de estado de aislamiento SOAR.

9. Criterios de Escalado

Transición	Condición de escalado	Destinatario	Tiempo máximo
L1 → L2	Confirmación de actividad maliciosa tras el triage inicial	Analista SOC L2	15 minutos
L2 → L3 / IR Lead	Evidencia de cifrado activo o 3+ hosts afectados	Threat Hunter / IR Lead	30 minutos
L2 → IR Lead	Fallo de la contención automatizada del SOAR (requiere contención manual)	IR Lead / CSIRT completo	INMEDIATO
IR Lead → CISO / Dirección	Afectación a sistemas críticos, controladores de dominio, backups, o sospecha de exfiltración asociada	CISO, Dirección	1 hora
IR Lead → Legal / DPO	Posible afectación a datos personales o requisito regulatorio de notificación	Legal / DPO	1-2 horas
CISO → Autoridades	Confirmación de incidente con impacto significativo	CSIRT nacional / fuerzas de seguridad	Según marco regulatorio

10. Comunicación

- **Notificación interna inicial:** dirigida al IR Lead y roles de la sección 4. Incluir hora de detección, sistemas y usuarios afectados, estado de la contención y próximos pasos. Evitar información especulativa sobre causa raíz hasta su confirmación.

- **Notificación a Dirección / CISO:** resumen ejecutivo no técnico, impacto de negocio estimado (sistemas caídos, procesos afectados) y decisiones que requieren su autorización.
- **Postura ante el rescate:** la organización NO inicia ni autoriza negociación o pago de rescate sin autorización expresa y documentada de Dirección, con asesoría legal previa. Ningún analista o IR Lead está autorizado a realizar pagos unilaterales. El pago no garantiza la recuperación de los datos, financia grupos criminales y puede constituir una infracción legal si el grupo está sancionado internacionalmente (OFAC).
- **Notificación regulatoria:** Legal/DPO determina si aplica notificación obligatoria (RGPD: máximo 72 horas desde el conocimiento; NIS2; normativa sectorial). El IR Lead provee la información técnica dentro del plazo definido en la sección 9.
- **Comunicación externa:** gestionada exclusivamente por Comunicación/RRPP bajo aprobación de Dirección. Ningún miembro técnico realiza declaraciones externas.

11. Métricas de Cierre

- **MTTD (Mean Time to Detect):** tiempo desde la ejecución inicial del payload hasta la generación de la alerta correlacionada en el SIEM.
- **MTTC (Mean Time to Contain):** tiempo desde la alerta hasta el aislamiento confirmado del host. Referencia: menos de 10 segundos para la contención automatizada vía SOAR.
- **MTTR (Mean Time to Recover):** tiempo desde el inicio de la contención hasta la reintegración validada del sistema a producción.

Evidencia mínima a documentar para el cierre:

- Cronograma cronológico completo (timestamps de cada fase y acción ejecutada).
- Hashes e IOCs confirmados (binarios, dominios C2, direcciones IP).
- Alcance final: hosts, usuarios, datos y sistemas afectados.
- Vector de entrada confirmado y evidencia de la corrección aplicada.
- Acciones de contención, erradicación y recuperación con responsable y timestamp.
- Resultado de la revisión de falso positivo del SOAR si aplicó (brecha #8 corregida en v2.0).
- Hallazgos de lecciones aprendidas y cambios aplicados al playbook.

12. Revisión y Mantenimiento

1. Este playbook se revisa semestralmente o tras cualquier incidente real que lo active.
2. Toda modificación queda registrada en el control de versiones y debe ser aprobada por el CISO.
3. Los roles de la sección 4 se validan trimestralmente contra el esquema de guardias (on-call) del SOC.
4. Los plazos de notificación regulatoria de la sección 10 se confirman con Legal/DPO ante cambios normativos.
5. El procedimiento de reversión de falso positivo del SOAR (sección 6.2) debe probarse en simulacro al menos anualmente.

13. Control de Versiones

Versión	Fecha	Cambios	Autor
1.0	Jun. 2026	Versión inicial: flujo de detección y contención automatizada (SIEM/SOAR). Solo cubre Detección y Contención.	SOC
2.0	20 jun. 2026	Versión completa: ciclo NIST íntegro, roles, mapeo MITRE (8 técnicas), escalado con tiempos, comunicación (postura rescate), métricas de cierre, preservación de evidencia forense, reversión de falso positivo SOAR. Corrige las 9 brechas del informe de revisión.	SOC

INFORME DE REVISIÓN Y PROPUESTA DE MEJORA

Playbook de Respuesta ante Incidentes de Ransomware (SOC-IR-042)

Campo	Detalle
Documento revisado	SOC-IR-042 — Versión 1.0 (Junio 2026)
Documento de referencia	Playbook SOC-IR-042 — Versión 2.0 (documento independiente)
Tipo de documento	Informe de revisión técnica y propuesta de ampliación
Clasificación	Confidencial / Uso Interno
Marcos de referencia	NIST SP 800-61 Rev. 2, MITRE ATT&CK, SANS Incident Handler's Handbook, ISO/IEC 27035
Fecha del informe	21 de junio de 2026
Elaborado por	Asistente de Ciberseguridad Defensiva (Blue Team)

Nota: este informe documenta el análisis y los hallazgos de la revisión. El procedimiento operativo completo y definitivo se entrega como documento independiente: *Playbook de Respuesta ante Ransomware — SOC-IR-042 v2.0*.

1. Resumen Ejecutivo

El playbook SOC-IR-042 v1.0 documenta de forma sólida el flujo de detección automatizada y contención inicial frente a ransomware, apoyado en una arquitectura SIEM/EDR/SOAR bien integrada y con tiempos de respuesta agresivos (aislamiento de host en menos de 10 segundos). Sin embargo, en su estado original el documento cubría únicamente dos de las seis fases del ciclo de respuesta a incidentes definido por NIST SP 800-61 (Detección y Análisis, Contención), y omitía elementos que un Procedimiento Operativo Estándar (POE) debe incluir para ser ejecutable de forma completa durante un incidente real: roles y responsables, erradicación, recuperación, lecciones aprendidas, mapeo explícito a MITRE ATT&CK, criterios de escalado, pautas de comunicación y métricas de cierre.

Este informe documenta los hallazgos de la revisión. La versión ampliada y definitiva (v2.0), que conserva íntegramente las Fases 1 y 2 originales (SIEM y SOAR) y las integra dentro del ciclo de vida completo de gestión de incidentes, se entrega como documento independiente para uso operativo directo del SOC.

Recomendación principal: no operacionalizar el playbook v1.0 en su forma original como respuesta única a un incidente de ransomware; usar en su lugar la versión 2.0 completa, que incorpora como mínimo los procedimientos de erradicación, recuperación, roles de decisión y comunicación necesarios dado el impacto reputacional, legal y operativo característico de este tipo de incidente.

2. Alcance y Metodología de la Revisión

La revisión se realizó sobre el documento SOC-IR-042 v1.0 (4 páginas: Resumen Ejecutivo, Diagrama de Flujo Lógico, Fases de Ejecución Técnica y Tabla de Herramientas Recomendadas), contrastándolo contra una checklist de nueve elementos que debe contener un playbook de respuesta a incidentes operativo, derivada de los siguientes marcos de referencia:

- **NIST SP 800-61 Rev. 2** — ciclo de vida de gestión de incidentes: Preparación, Detección y Análisis, Contención/Eradicación/Recuperación, Actividad Post-Incidente.
- **MITRE ATT&CK** — taxonomía de tácticas y técnicas adversarias (TTPs) para mapear cobertura de detección.
- **SANS Incident Handler's Handbook** — estructura PICERL y buenas prácticas de documentación operativa.
- **ISO/IEC 27035** — gestión de incidentes de seguridad de la información, incluyendo roles, comunicación y mejora continua.

Los nueve elementos evaluados fueron: (1) nombre y alcance del playbook, (2) triggers de activación, (3) roles y responsables, (4) fases del proceso según el ciclo NIST, (5) acciones técnicas concretas por fase, (6) mapeo a MITRE ATT&CK, (7) criterios de escalado, (8) pautas de comunicación y (9) métricas de cierre.

3. Fortalezas del Playbook Original

Los siguientes elementos del documento v1.0 están bien contruidos y se conservan sin modificaciones sustanciales en la versión 2.0:

- **Diagrama de flujo lógico claro**, con puntos de decisión binarios (¿filtro de correo frena la amenaza?, ¿el EDR frena el proceso?) que permiten un triage visual rápido.
- **Telemetría de detección concreta**: uso de Sysmon Event ID 1 para creación de subprocesos sospechosos y detección de intérpretes de comandos (powershell.exe, cmd.exe) invocados con argumentos codificados desde procesos de usuario.
- **Detección de red orientada a C2**: identificación de conexiones salientes a IPs externas sin resolución DNS previa, un indicador de comportamiento robusto frente a IOC's estáticos.
- **Orquestación SOAR con tiempos definidos**: aislamiento de host vía API en menos de 10 segundos, manteniendo activo el canal de gestión TLS con la consola del SOC.
- **Bloqueo específico de vssadmin.exe**: medida de hardening que corresponde directamente a la técnica MITRE T1490 (Inhibit System Recovery).
- **Coordinación NOC/SOC documentada**: buena práctica operativa poco habitual de ver documentada explícitamente.
- **Tabla de herramientas con configuraciones críticas**: especifica acciones de configuración concretas en lugar de listar productos sin contexto.

4. Hallazgos y Brechas Identificadas

Se identificaron nueve brechas frente a la checklist de referencia. La siguiente tabla resume cada hallazgo, el riesgo asociado a no corregirlo y la prioridad de remediación.

#	Brecha identificada	Riesgo si no se corrige	Prioridad
1	No se definen roles ni responsables (L1/L2/L3, IR Lead, Legal, Dirección)	Decisiones críticas sin dueño claro durante el incidente; retrasos por ambigüedad de mando	Alta
2	Faltan 4 de las 6 fases NIST: Preparación, Erradicación, Recuperación, Lecciones Aprendidas	El playbook se detiene tras la contención; no hay procedimiento para recuperar operaciones de forma segura	Alta
3	No hay mapeo explícito a MITRE ATT&CK (solo se menciona como configuración del SIEM)	Cobertura de detección no auditable ni comparable contra el marco de referencia del sector	Media

#	Brecha identificada	Riesgo si no se corrige	Prioridad
4	No se definen criterios de escalado (umbrales, destinatarios, tiempos)	Riesgo de que un incidente mayor se gestione con la urgencia de uno menor, o viceversa	Alta
5	Ausencia total de pautas de comunicación (interna, Dirección, regulatoria, postura ante rescate)	Incumplimiento de plazos regulatorios y mensajes descoordinados	Alta
6	No se especifican triggers de activación formales (solo implícitos en el diagrama)	Activación tardía o inconsistente del playbook ante variantes del vector de ataque	Media
7	No hay métricas de cierre (MTTD/MTTR) ni checklist de evidencia para el post-mortem	Imposibilidad de medir eficacia de la respuesta o alimentar la mejora continua (ISO 27035)	Media
8	Automatización del SOAR sin procedimiento de reversión de falso positivo ni gate de aprobación	Aislamiento erróneo de un sistema crítico sin vía de reversión documentada	Alta
9	No se documenta preservación de evidencia antes de remediar (forense/memoria)	Pérdida de evidencia necesaria para atribución, seguro cibernético o procedimiento legal	Media

5. Resumen de la Ampliación Propuesta (v2.0)

Cada una de las nueve brechas identificadas en la sección 4 fue resuelta en la versión 2.0 del playbook. La siguiente tabla indica dónde se aborda cada una dentro del documento operativo independiente; no se reproduce aquí el contenido completo para evitar duplicación entre ambos documentos.

Brecha #	Elemento incorporado	Sección en Playbook SOC-IR-042 v2.0
1	Roles y responsables (L1/L2/L3, IR Lead, Legal, Dirección, NOC)	Sección 4 — Roles y Responsables
2	Fases NIST completas: Preparación, Erradicación, Recuperación, Lecciones Aprendidas	Sección 6 — Fases del Proceso (6.0 a 6.5)
3	Mapeo explícito a MITRE ATT&CK (tácticas y técnicas por fase)	Sección 7 — Mapeo a MITRE ATT&CK
4	Criterios de escalado (umbrales, destinatarios, tiempos)	Sección 9 — Criterios de Escalado
5	Pautas de comunicación interna, regulatoria y postura ante el rescate	Sección 10 — Comunicación
6	Triggers de activación formales	Sección 3 — Trigger / Criterios de Activación
7	Métricas de cierre (MTTD/MTTR) y checklist de evidencia	Sección 11 — Métricas de Cierre
8	Contención manual de respaldo si falla la automatización del SOAR	Sección 6.2 — Contención
9	Preservación de evidencia forense antes de remediar	Sección 6.2 — Contención

El documento Playbook SOC-IR-042 v2.0 incluye además el diagrama de flujo consolidado (con opciones de herramientas por fase), la tabla de herramientas y configuraciones críticas, y el control de versiones del propio procedimiento operativo.

6. Recomendaciones y Próximos Pasos

1. Formalizar la sección de Roles y Responsables del Playbook v2.0 con nombres/equipos reales y validar la disponibilidad de cada rol en el esquema de guardias (on-call) del SOC.
2. Completar y probar mediante un simulacro (tabletop exercise) las fases de Erradicación y Recuperación antes de considerar el playbook operativo en producción.
3. Validar con Legal/DPO los plazos exactos de notificación regulatoria aplicables a la organización y dejarlos documentados explícitamente en la sección de Comunicación.
4. Definir e implementar el procedimiento de reversión de falso positivo para las acciones automatizadas del SOAR (brecha #8), incluyendo un gate de aprobación para activos críticos si el modelo de confianza de la organización lo requiere.
5. Revisar y actualizar el Playbook con periodicidad semestral o tras cada incidente real que lo active, conforme al ciclo de mejora continua de ISO/IEC 27035.
6. Replicar esta misma checklist de nueve elementos sobre el resto de playbooks del SOC (phishing, exfiltración, acceso no autorizado, DDoS) para asegurar consistencia documental en todo el catálogo.

7. Historial del Informe

Versión	Fecha	Cambios	Autor
1.0	20 jun. 2026	Revisión inicial del playbook v1.0: fortalezas, brechas y propuesta de ampliación detallada	Asistente de Ciberseguridad Defensiva
1.1	21 jun. 2026	Reestructuración: se elimina la duplicación del contenido operativo (ahora exclusivo del Playbook v2.0, documento independiente) y se reduce a un informe de análisis	Asistente de Ciberseguridad Defensiva